

Mirza Bot: PHP → Python rewrite parity audit

An independent, static-only review of the `rewrite/python` branch against production `main`, treating every behaviour in `main` as a requirement.

BASELINE

63.6k LOC

REWRITE LOGIC

8.0k LOC

FEATURES SCORED

96

WEIGHTED PARITY

≈ 55%

CRITICAL DEFECTS

4

DATE

2026-08-25

01 Executive summary

The rewrite is a **well-structured, genuinely more maintainable skeleton that is not yet feature-complete** — and, critically, is broken on the one path the whole product exists for: **taking money and delivering a config**. Architecturally it is a real step up from the PHP monolith: a plugin registry for panels, payments and jobs; an ORM with real foreign keys and indexes; JSONB settings; Fernet-encrypted panel passwords; idempotent payment claiming; and proper Telegram Mini-App signature validation. As a *foundation to build on*, it succeeds.

Measured against the actual instruction — **full feature parity with `main`** — it is roughly half-done, and the missing half includes the revenue path. Three independent defects each break online payments on their own:

- #1 `PaymentService.settle_wallet_topup(...)` is called in four places but **defined nowhere**. Every wallet top-up settlement — Zarinpal, IranPay, Plisio, NowPayments, card-to-card, Telegram Stars — raises `AttributeError` at runtime.
- #2 Paying for a **product** through any online gateway **never provisions it**. The bot checkout creates the order with no `invoice_id`, so settlement treats the purchase as a wallet top-up (which then hits #1).
- #3 The customer is **never notified** when a gateway payment settles (`_notify_user(None, ...)`) and the admin payment report is a **no-op placeholder**.

The single biggest risk is therefore not "some features are missing." It is that **the money path looks finished** — there are gateway modules, a passing test suite, and a self-authored `PARITY.md` claiming  almost everywhere — **yet it does not work**

end-to-end, and the tests are green because they never exercise the broken branch. Anyone trusting the self-reported matrix would ship a bot that accepts payment and hands out nothing.

Beyond payments, the admin surface is a fraction of the original (~25 mostly create-and-list commands versus ~177 branches in `admin.php`; no multi-admin support, no in-bot text customization, no per-panel pricing or inbound editing). Several scheduled jobs are stubs or point at the wrong destination — expiry reminders go to an admin channel instead of the customer, the lottery job is absent, and the gift job is literally `return None`. A number of admin-configurable settings are written but never read (lucky-wheel prizes, gift-code percentages).

55%
WEIGHTED PARITY

✗ Not ready to replace main

Far off as a drop-in replacement; **close** as an architectural foundation. Completion clusters in read/display paths, so functional readiness of the purchase flow is materially lower than 55%. Do not cut over until the §8 must-fix list is cleared and a dynamic pass confirms provisioning against real panels.

02 How this pass was conducted

- Both branches read directly from git worktrees; **no code executed**, no dependencies installed, no PostgreSQL or panels contacted.
- Breadth-first, risk-weighted:** every functional area inventoried and mapped; deep line-level scrutiny concentrated on the money path, scheduled jobs, auth, and the data model.
- The rewrite's own `PARITY.md` was treated as **a claim to verify, not evidence** — several of its  entries are contradicted by the code and are called out inline.
- Where a conclusion is inferred rather than proven by reading, it is labelled as such. The honest depth boundary is stated in §10.

03 Feature parity inventory

 Done

 Improved

 Partial

 Buggy / wrong

 Risky

 Missing

4.1 • Purchase & provisioning				
ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-001	Category browsing	Category → product drill-down		buy.py
F-002	Product listing / selection	Filtered by category / location		buy.py, mini_services
F-003	Location choice at checkout	Per-product location honoured		Bot flow has no location pick; _default_panel grabs first non-/all product
F-004	Automated config creation	Create panel user, return config/sub		panels/service.py::create_user
F-005	Wallet purchase	Deduct balance then provision, atomically		Provisions & commits invoice BEFORE charging; failed charge → free config; double-spend race
F-006	Online-gateway product purchase	Pay via gateway → provision product		No invoice_id on order → mis-routed to (broken) wallet top-up; product code discarded
F-007	Discount at checkout	Percent / fixed / limits / per-product		Only fixed applied; percent ignored; used_count not incremented; expiry & DiscountSell unused
F-008	One-purchase-per-plan guard	one_buy_status blocks re-buy		Enforced in Mini-App only, not bot buy path
F-009	QR code for config	QR image of config / sub		Not found in rewrite
F-010	Sub link / /sub proxy	Proxy subscription content		api/subproxy.py; subvip rewrite
F-011	Protocol / inbound config	Product inbounds + protocol table		inbounds passed through; protocol table absent from model

4.2 · Service management

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-012	View purchased services	List invoices + live panel data		services.py, mini_invoices (ownership-checked)

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-013	Renew / extend service	Add time ($\pm$ volume / reset)		Volume math questionable; service_time semantics inconsistent
F-014	Buy extra volume	Add GB to live config, paid		extra_volume modifies panel; payment linkage thin
F-015	Buy extra time	Add days to live config, paid		extra_time; same payment caveat
F-016	Change location (paid)	Recreate preserving quota, remove old		create_user(data_limit=0, expire=now) → dead config; quota dropped
F-017	Revoke subscription link	Rotate sub token		revoke_sub → adapter
F-018	Config / sub retrieval	Re-send config & link		services / mini-app
F-019	User disable / enable service	User pauses a service		Simplified vs legacy disorder flow
F-020	Cancel / delete service	cancel_service + admin review		Table exists; flow unconfirmed

4.3 · Payments & wallet

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-021	Wallet balance & ledger	Balance + ad-hoc adjustments		Append-only balance_ledger (auditable)
F-022	Wallet top-up via gateway	Pay → credit balance		settle_wallet_topup UNDEFINED (called 4×) → AttributeError
F-023	Card-to-card (manual)	Receipt → admin approve → credit		card2card + croncard + paycheck; incomplete + shares broken settle
F-024	Zarinpal	PG v4 verify		Module exists; settlement blocked by F-006/022
F-025	Aqayepardakht	Code-70 replay-safe		Module exists; settlement caveat
F-026	NowPayments	Crypto webhook + poll		Module + poll; settlement caveat

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-027	Plisio	Crypto poll		Module + poll; settlement caveat
F-028	IranPay	Factor poll		Legacy return-in-while bug fixed; settlement caveat
F-029	CubePay (TRON)	HMAC callback + result page		Signed callback, fee math, HTML card; unit-tested offline
F-030	Telegram Stars	Invoice, pre-checkout, settle		Settlement calls undefined settle_wallet_topup → crash
F-031	Payment idempotency	Avoid double-settlement		claim_paid atomic UPDATE... WHERE Unpaid
F-032	Payment report → channel	Rich report to report group		_report() is a no-op placeholder
F-033	User notification on payment	DM buyer on success		_notify_user(None, ...) — bot hardcoded None
F-034	Pending-payment expiry	Expire stale orders		payment_expire job (fail after 1h)

4.4 · Bot UX & onboarding

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-035	/start, menu, deep-link	Menu + ref_capture		menu.py
F-036	Language switch (fa/en/ru/zh)	Per-user language		i18n + middleware
F-037	Accept-rules gate	Must accept before use		Legacy acceptRules not observed
F-038	Forced channel membership	Multi-channel mandatory join		Single channel_lock only; channels table not enforced; _check_member fails open
F-039	Phone / number verification	iran_number blocks purchase		/api/verify sets status; no enforcement in purchase path

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-040	Ban / block enforcement	Blocked users can't act		AuthMiddleware + mini-app check
F-041	FSM / step persistence	Step + scratch in DB		Process-local dicts (buy/topup/broadcast/sessions); lost on restart; multi-worker races

4.5 · Growth & marketing

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-042	Referral link + count	Show link, count referred		misc.affiliates, menu captures referrer_id
F-043	Referral commission payout	Referrer earns on referred buy		porsant_one_buy / reagent_report / status_commission unused
F-044	Cashback rewards	Cashback on spend		Only hardcoded cashback=0 in _settle
F-045	Discount codes (admin)	Create % / fixed, limits		/giftcode creates inert code (percent=0/price=0)
F-046	Gift codes	Redeemable credit + scheduled drops		Consumed count collapses to ≤1; gift job is return None
F-047	Lottery (scheduled draw)	cronbot/lottery.php periodic draw		No lottery job (main has 17, rewrite ships 16)
F-048	Lucky wheel (daily)	Daily spin, admin prizes		Hardcoded WHEEL_PRIZES; /wheelprizes setting never read

4.6 · Agent / reseller

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-049	Agent grant / revoke / list	Multiple agent levels		Single agent_level='a'
F-050	Agent request approval	Request → admin approve		No user notify / panel grant on approval
F-051	Agent types & pricing (n/n2)	Distinct reseller tiers		Not ported

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-052	Agent expiry	Auto-demote expired agents		expireagent job
F-053	Agent panel provisioning	mirza_agent.php		Adapter present; not deep-verified

4.7 · Support & content

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-054	Support contact	Show support handle		misc.support
F-055	Ticketing via departments	Departmental tickets + tracking		extra.py + Departman; admin add/list only
F-056	FAQ / tutorials browsing	Help entries by OS/category		menu help + help CRUD
F-057	Tutorial media (photo/video)	Media-rich tutorials		/addhelp stores text only

4.8 · Admin management

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-058	Stats dashboard	Rich financial / user stats		Counts + revenue only
F-059	User management	Find / block / balance / limits		No maxbuyagent / changeloclimit / expireset / verify mgmt
F-060	Product CRUD	Full create/edit/delete + fields		addproduct + list; no edit/delete; drops most fields
F-061	Panel CRUD	Full editing incl. pricing/inbound		add + list + toggle; no edit; pricing/inbound/test not editable
F-062	Category CRUD	Add/list/delete/reorder		add/list/delete
F-063	Discount / gift CRUD	Full management		Create/list only
F-064	Channel management	Register + lock multiple		add/list + single lock; multi not enforced

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-065	Department CRUD	Manage departments		add/list only
F-066	Manual sell (/sell)	Admin gifts a real plan		Provisions data_limit=0; ignores product vol/days; arbitrary panel
F-067	Broadcast	Text/media/pin/forward, batched		Text only; one DB session per use (O(N))
F-068	Multiple admins + rule levels	admin table, permission levels		AdminGate = only primary admin contradicts PARITY 
F-069	In-bot text customization	Edit any bot string from bot		No settext/bottext handler — headline main feature
F-070	Username generation methods	Multiple configurable strategies		random / number only
F-071	Card-number management	Add/remove/toggle cards		Model exists; no admin handler
F-072	Report-topic configuration	Map reports → forum topics		topicid model exists; no config UI
F-073	Settings toggles	Dozens of operational flags		Web panel exposes ~5 keys
F-074	Payments report (/payments)	Recent payments list		payments_report
F-075	Lucky-wheel prize config	Configure prizes		Writes wheel_prizes; wheel never reads it

4.9 · Scheduled jobs (cron)

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-076	Expiry reminders → user	DM buyer before expiry + renew btns		Only send_report to admin channel; customer never notified
F-077	Volume warnings → user	DM at ≥80% usage		Posts to report channel, not user

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-078	Disable expired configs	Disable on panel + persist		Disables on panel but never commits status
F-079	Re-activate / renew configs	Re-enable renewed configs		activeconfig (commits)
F-080	On-hold activation	Activate on-hold at first use		Job exists but no handler sets on_hold; day-count math bug
F-081	Trial cleanup	Remove expired trials		configtest
F-082	Node uptime monitor	Alert on down nodes		Adapter built with ENCRYPTED password (not decrypted) → auth fails
F-083	Panel uptime monitor	Alert on unreachable panels		uptime_panel
F-084	Automatic backups	pg_dump / mysqldump / sqlite		backup.py present; not deep-verified
F-085	Daily status report	Rich nightly financial report		New-user + counts only

4.10 · Web / HTTP surfaces

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-086	Web admin panel	Full CRUD admin (~90k bytes PHP)		List-only dashboards + 5-key settings; in-memory sessions
F-087	Mini-App backend API	Signed-request user API		Session-token identity, ownership checks, initData HMAC
F-088	Mini-App static serving	Serve the SPA bundle		miniapp_static.py
F-089	Telegram webhook + secret	Receive updates		Validates secret (improvement) but fails open if unset
F-090	Sub proxy	Serve subscription content		subproxy.py
F-091	White-label child bots	Per-child dispatch (botsaz)		whitelabel.py + model; not deep-verified

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-092	Machine API tokens	hash.txt token auth for /api		auth (constant-time) + session dual-auth

4.11 · Data & infrastructure

ID	FEATURE	MAIN BEHAVIOUR	STATUS	NOTES
F-093	DB schema parity	~30 MySQL tables		29 modelled well; protocol table missing; setting redesigned to KV (no compat view)
F-094	Migrations	Schema versioning		0001_initial is create_all in disguise; dead col_defs loop; no real DDL
F-095	Panel password encryption	(plaintext in main)		Fernet at rest (improvement); key from change-me default = known key
F-096	Installer	Apache/PHP/MySQL/certbot		systemd + Caddy + alembic; different stack, unverified

04 Additions in the rewrite

Genuinely useful and mostly aligned with the "improve where reasonable / design for extension" instruction. Crucially, these are **labelled** in `PARITY.md` rather than silently mixed into parity work — that instruction was followed. The problem is the false  parity claims sitting beside them.

- **Plugin registry** for panels, payments and jobs (`@register_plugin`) with runtime enable/disable — the main extensibility win.
- **Append-only balance ledger** — auditable wallet.
- **Idempotent payment claiming** (`claim_paid`) — correct concurrency guard (undermined in practice by the settle bug).
- **Webhook secret validation** — closes a real main gap (fails open if unset).
- **Fernet encryption of panel passwords at rest** (weak-default-key caveat).
- **JSONB settings, real FKs and indexes** on the invoice/payment hot paths.
- **Proper Telegram `initData` HMAC validation** for the Mini-App — stronger than main.
- **Batched / rate-capped** broadcast and payment polling.

05 Architecture & extensibility

This is the rewrite's strongest dimension, and the instruction to "design for future add-ons" was taken seriously rather than producing a literal transliteration.

Concretely:

- **Clean module boundaries:** `handlers/` (bot), `panels/` (provisioning adapters), `payments/` (gateways), `jobs/` (scheduler), `api/` (HTTP), `models/`, `i18n/`. This is a real separation the PHP monolith (a 10.9k-line `admin.php`, a 6.7k-line `index.php`) never had.
- **A genuine plugin system:** `registry/` plus a `contracts.py` defining `PanelAdapter`, `PanelResult` and `Job` interfaces. Adding a panel or gateway is a new class with a decorator — the correct extension seam, and the clearest evidence this is designed to grow.
- **Config-driven where it counts:** a settings KV store and per-panel columns replace scattered PHP constants; the scheduler is toggleable like the legacy `status_cron`.

The extensibility is undercut in three places where the design reverts to hardcoding:

process-local dictionaries for purchase, top-up, broadcast and web-session state (breaks multi-worker and restarts); **single-admin gating** that ignores the `Admin` / `rule` tables; and **hardcoded values** that shadow admin config (wheel prizes, trial limits). The bones are extensible; several muscles are still nailed in place.

06 Code quality & QA findings

■ Critical — blocks launch

- 1 **Undefined `settle_wallet_topup`** — every gateway top-up and Stars settlement crashes. F-022 · F-030
- 2 **Gateway product purchase never provisions** — missing `invoice_id` mis-routes real purchases to the broken top-up branch. F-006
- 3 **Buyer never notified & admin report is a no-op** on settlement. F-032 · F-033
- 4 **Wallet purchase provisions & commits the invoice before charging** — a failed charge only rolls back an already-committed session → free config; TOCTOU double-spend. F-005

■ High

- 1 **Change-location & manual-sell create zero-volume / expired configs.** F-016 · F-066
- 2 **Expiry & volume reminders go to an admin channel, not the customer** — the renewal engine never reaches buyers. F-076 · F-077
- 3 `disableconfig` **never commits** its status change; re-runs every tick. F-078
- 4 **Multiple-admins unimplemented** despite a  claim; secondary admins are locked out. F-068
- 5 **Migrations are** `create_all` **in disguise** with dead code and no compatibility view for the redesigned settings table. F-094 · F-093
- 6 **Process-local state** breaks restarts and any multi-worker deployment; enables the F-005 race. F-041

■ Medium

- Discount engine ignores percentages, usage limits, per-product codes and expiry. F-007 · F-045
- Lucky-wheel & gift-code admin config written but never read. F-048 · F-075 · F-046
- Lottery job and scheduled gift drops absent / stubbed. F-047
- `uptime_node` uses the encrypted password without decrypting. F-082
- Referral commission & cashback not implemented. F-043 · F-044
- Admin surface ~25 commands vs ~177; no in-bot text customization; pipe-delimited CLI args replace interactive flows.
- `service_time` stores an absolute timestamp in some paths and a day-count in others → on-hold / extend math bugs. F-080 · F-013

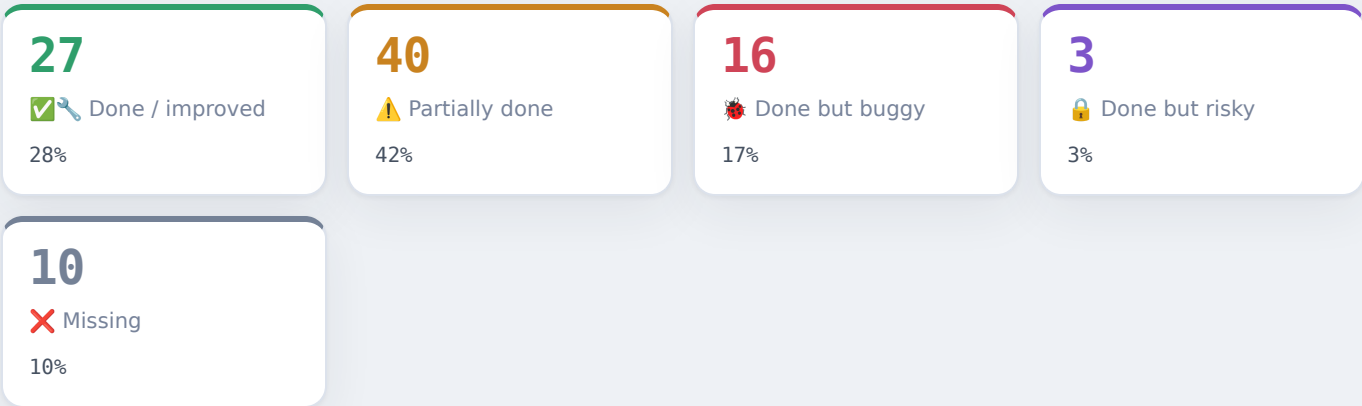
■ Low / hygiene & testing

- **Dead / placeholder code (AI-generation tells):** a shadowed insecure duplicate `miniapp` in `api/__init__.py` (its token action trusts a client `user_id`); `payhooks._report`; `service._expire_from`; the migration `col_defs` loop; `r = web.Application() # placeholder to keep linters calm`; `_TOPUP_UNUSED`; `new_tracking_code`.
- Web panel: no `Secure` cookie flag; inconsistent HTML-escaping; a bcrypt timing-parity "dummy hash" that is invalid and raises. **SQL is parameterized via the ORM — no injection found.**
- Webhook secret and forced-channel checks **fail open** when misconfigured. Weak default `MIRZA_SESSION_SECRET=change-me` doubles as the panel-password encryption key.
- **Testing:** 38 test functions, strong on `initData`, CubePay/Stars math and idempotency — but **no test exercises the settle-topup or bot checkout path**, which is exactly why the suite is green while

the money path is broken. Components are validated in isolation; the end-to-end purchase journey is never assembled.

07 Completion & how it was calculated

Each of 96 parity features is scored by fidelity to baseline (Done/Improved = 1.0, Risky = 0.7, Partial = 0.5, Buggy = 0.2, Missing = 0.0) and averaged. Additions are excluded from the denominator.



READ THE NUMBER CAREFULLY

Completion is concentrated in read/display paths (viewing services, stats, listings, the Mini-App). The transactional core — take payment → provision → notify — is where the buggy cluster sits. A user-journey-weighted score would land well below 55%. Treat 55% as "how much of the surface area is present," not "how ready it is to run a shop."

Weighted completion by functional area				
AREA	COMPLETION		READING	
Web / HTTP surfaces		86%	Solid	
Support & content		75%	Solid	
Service management		63%	Partial — needs work	
Bot UX & onboarding		60%	Partial — needs work	
Payments & wallet		56%	Partial — needs work	
Purchase & provisioning		55%	Partial — needs work	
Data & infrastructure		55%	Partial — needs work	
Scheduled jobs		53%	Partial — needs work	

AREA	COMPLETION	READING
Agent / reseller		50% Partial — needs work
Admin management		41% Weak — major gaps
Growth & marketing		31% Weak — major gaps

08 Recommended next steps

MUST FIX BEFORE REPLACING MAIN — the "make the core actually work" tranche (1-7); land together with an end-to-end test.

- 1 Define `PaymentService.settle_wallet_topup(order, cashback_pct=0)` and cover it with a settlement test — unblocks all gateway top-ups + Stars.
- 2 Set `invoice_id` on gateway product orders in `buy.py::pay_gateway` so purchases provision instead of top up.
- 3 Wire a real bot into `payhooks` settlement — implement buyer DM and the admin report.
- 4 Fix wallet-purchase ordering: charge → provision in one transaction; re-verify balance atomically.
- 5 Fix change-location and manual-sell to carry real volume / expiry.
- 6 Point expiry & volume reminders at the customer; commit `disableconfig`.
- 7 Move ephemeral state to the DB / Redis (aiogram FSM) — removes the race and multi-worker breakage.

REACH REAL PARITY — the second tranche (8-14).

- 8 Restore money-adjacent admin parity: multi-admin gating, per-panel pricing/inbound/test config, product edit/delete, discount %/limits, card-number management, in-bot text customization.
- 9 Rewrite the discount engine (percent + fixed + per-product + usage-limit + expiry) and increment `used_count`.
- 10 Real migrations: replace the `create_all` shim with explicit DDL, and ship the compatibility view the settings redesign depends on.

- 11 Port the lottery job; implement gift drops; connect `/wheelprizes` to the wheel.
- 12 Referral commission & cashback; phone-verification enforcement; the on-hold creation path.
- 13 Harden config: require non-default secrets at boot; separate the encryption key from the session secret; add `Secure` cookies and consistent escaping.
- 14 Add end-to-end tests for the full purchase journey per gateway before re-claiming parity.

09 What could not be verified statically

Deferred to the second (live-run) pass:

- **Panel adapters against real panels.** Only `marzban.py` was deep-read (looks faithful). Marzneshin, Alireza/x-ui, S-UI, Hiddify, WGDashboard (keygen), MikroTik (REST v7), IBSng, Pasarguard, Rebecca and mirza_agent need live create/modify/remove/revoke round-trips.
- **The end-to-end purchase → payment → provision → notify flow** per gateway — confirm the \$6 crashes and the top-up mis-route on a running instance.
- **Alembic** `upgrade` / `downgrade` against real PostgreSQL (JSONB, FKs, the missing compat view, the absent `protocol` table).
- **Gateway callback signatures** against live sandboxes (Zarinpal v4, Aqayepardakht code-70, Plisio/NowPayments webhooks, IranPay poll, CubePay HMAC).
- **The Mini-App inside Telegram** (real `initData`, token exchange, purchase actions), **scheduled jobs** on the real scheduler, **white-label** child-bot dispatch, and the **installer** on a clean host.

10 Coverage statement

Fully read & reasoned about: data model & migration; bot purchase flow; `panels/service.py` ; `payments/service.py` ; payment webhooks; wallet; middleware; webhook entry; admin handlers; all scheduled jobs; web panel; REST + Mini-App API; user misc/menu; `marzban.py` .

Read lightly / trusted pending dynamic verification: individual gateway internals, `extra.py` , `services.py` detail, `whitelabel.py` , `backup.py` , `rates.py` , and 13 of the 14 panel adapters.

This is a complete **breadth-first** pass — every functional area inventoried and mapped, with deep scrutiny on the risk-weighted core. It is *not* a line-by-line audit of

all 89 rewrite and 97 baseline files; the areas above are the known depth boundary, and no partial result is presented as exhaustive.

Mirza Bot migration audit · static analysis pass 1 of 2 · generated 2026-08-25. Baseline origin/main (PHP 8.2 / MySQL) treated as source of truth; rewrite origin/rewrite/python (aiogram / SQLAlchemy / aiohttp / PostgreSQL). Feature IDs F-001...F-096 are stable references into the parity inventory. A companion PMO dashboard summarizes these figures visually.